M1: Initial AD Exploitation

Methodology: LLMNR / NBT-NS Poisoning

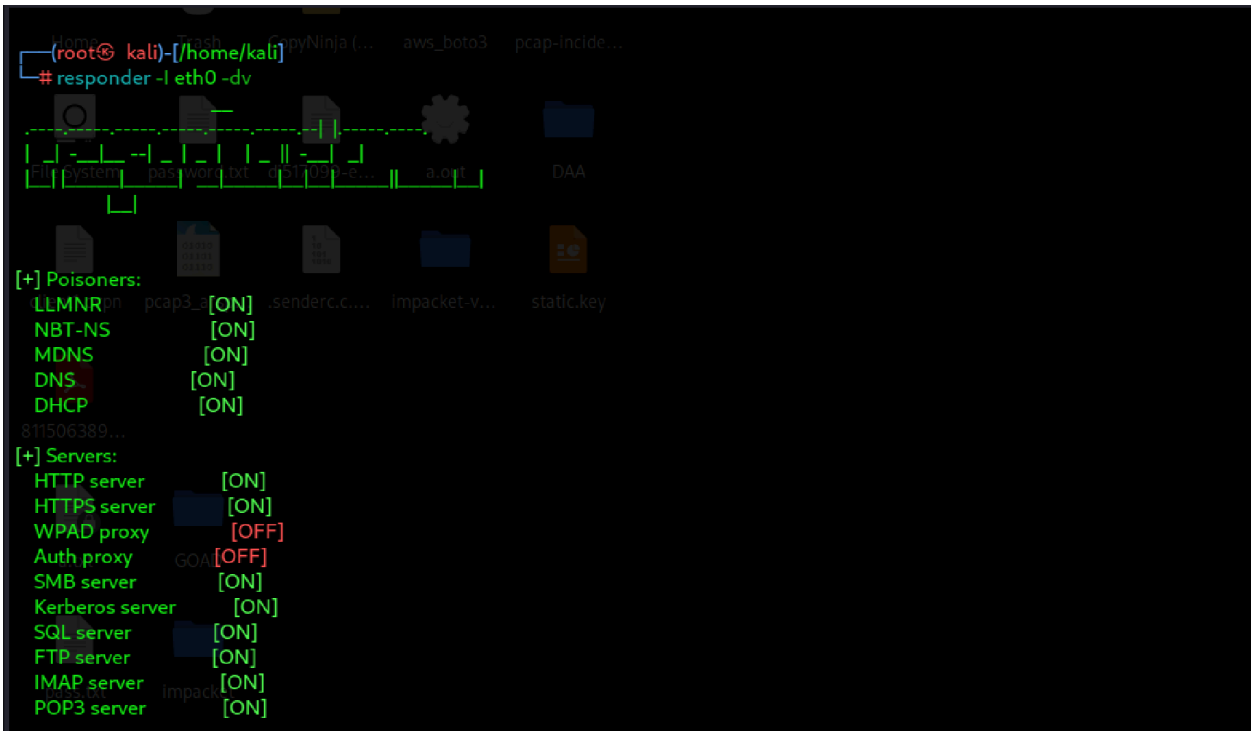
1. Overview

Link-Local Multicast Name Resolution (LLMNR) and NetBIOS Name Service (NBT-NS) are fallback protocols used by Windows for name resolution when DNS lookups fail. In this phase of the pentest, we exploit these protocols to intercept authentication requests and capture user credentials.

2. Execution Flow

Step 1: Listening for Requests
Using **Responder**, we set up a listener on the local network to intercept broadcasted queries. Based on the lab setup, the tool is initialized to listen on the primary ethernet interface.

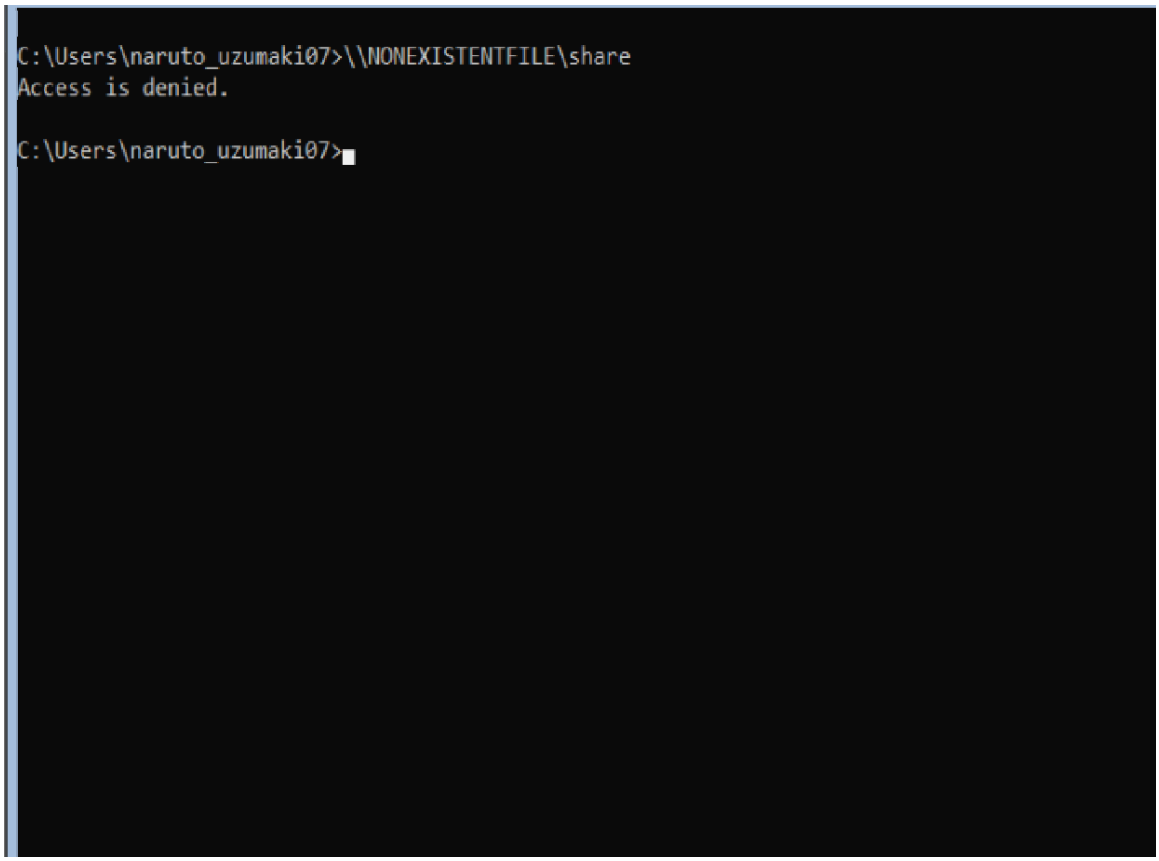
- **Command:** `responder -I eth0 -dv`
- **Result:** The listener successfully starts poisoners for LLMNR, NBT-NS, MDNS, DNS, and DHCP. It also activates servers for HTTP, SMB, and Kerberos to capture various authentication attempts.

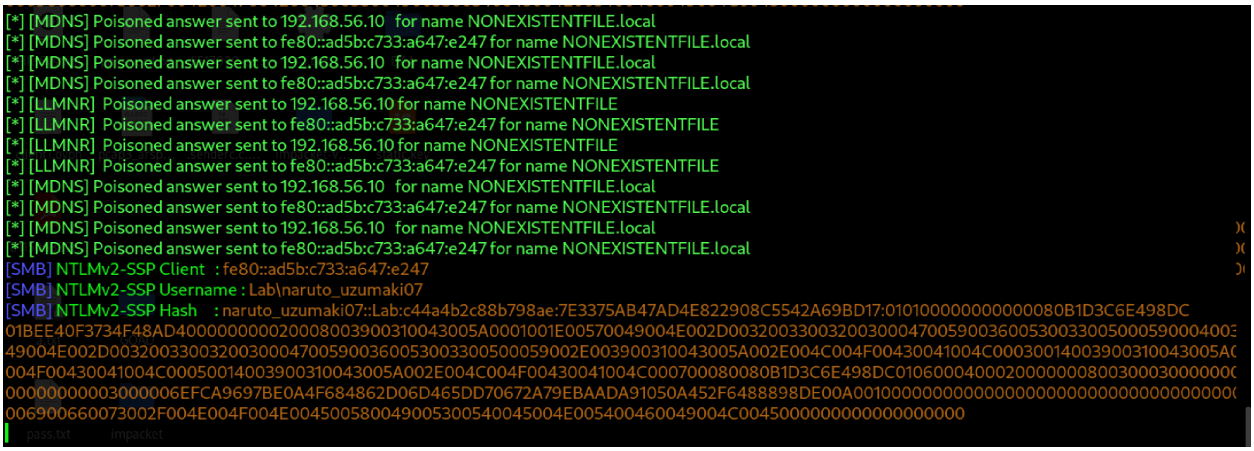


Step 2: Poisoning and Interception

Once a victim machine on the network (IP `192.168.56.10`) attempts to access a non-existent resource (e.g., `NONEXISTENTFILE`), Responder sends a spoofed response. The victim then attempts to authenticate with our machine.

- **Captured Data:** We successfully intercepted an **NTLMv2-SSP Hash**.
- **Target User:** `Lab\naruto_uzumaki07`
- **Target Machine IP:** `192.168.56.10`



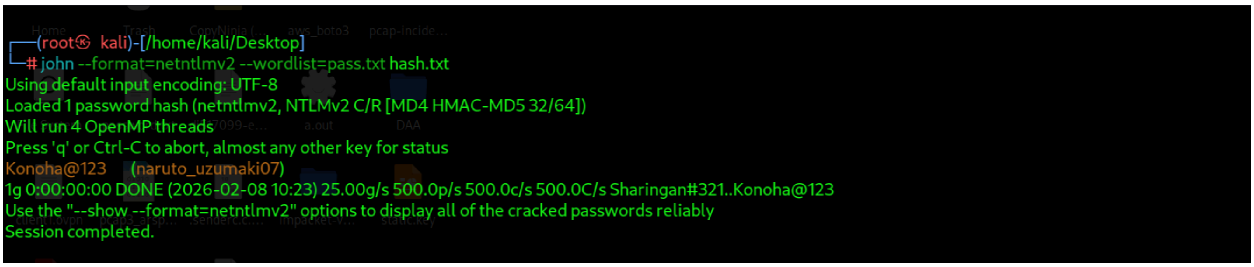


Step 3: Offline Password Cracking

The captured NTLMv2 hash is moved to a file for offline brute-force cracking. In this lab, **John the Ripper** was used with a custom wordlist.

- **Command:** `john --format=netntlmv2 --wordlist=pass.txt hash.txt`
- **Result:** The password was successfully cracked.

- **Credentials Found:** `naruto_uzumaki07 : Konoha@123`



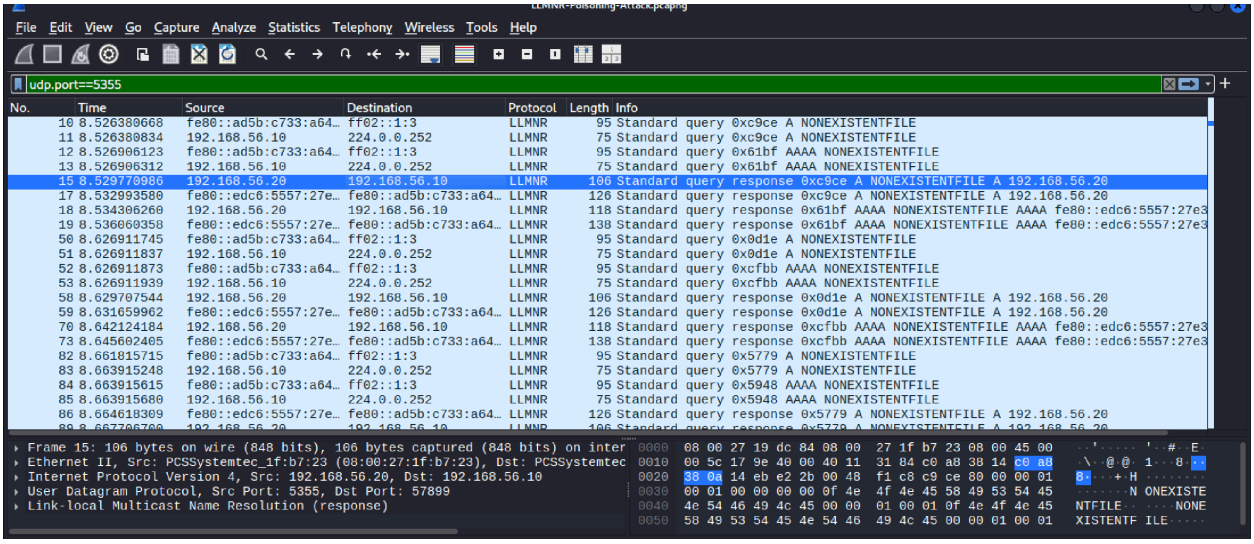
Detection

Now comes the **Detection** Part:
I captured the whole process in the WireShark till end and then detected each thing as a defender and finally got the requuired hash attaacker somehow managed to get from this LLMNR Poisoning and collected it in a exact format by analyzing it..

Phase 1: Identifying Malicious Name Resolution

In this phase, we analyze the network traffic to find the moment the poisoning occurred.

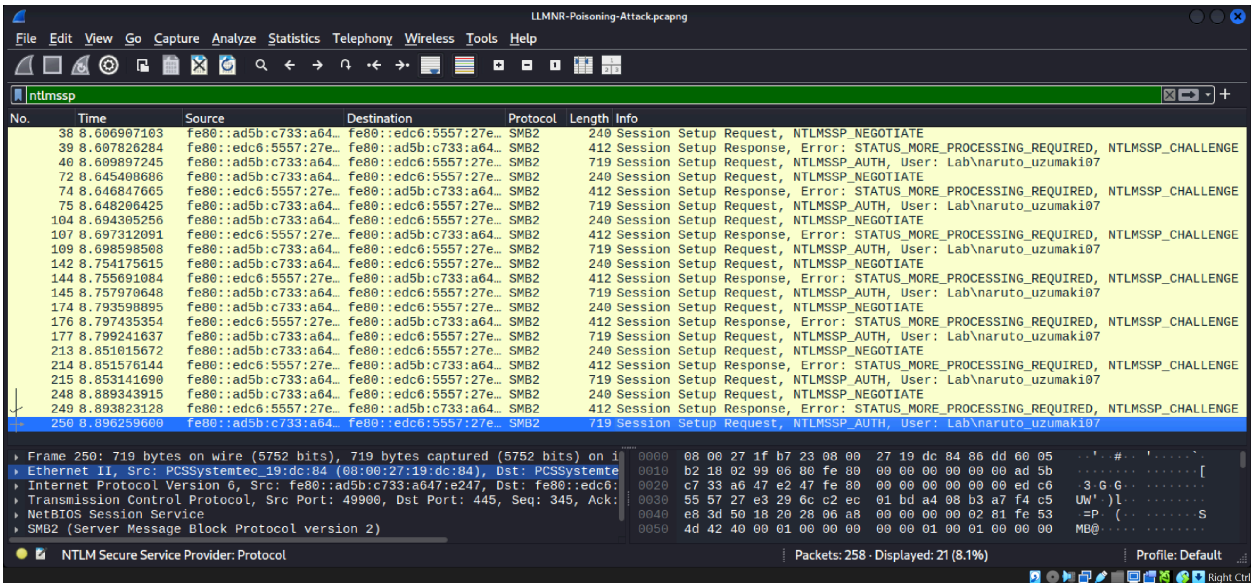
- **Filter Used:** `udp.port == 5355` (LLMNR) or `udp.port == 137` (NBT-NS).
- **Analysis:** * **The Request:** A victim machine (`192.168.56.10`) broadcasts a "Standard query" for a non-existent resource, such as `NONEXISTENTFILE`.
    - **The Poisoned Response:** A rogue machine (`192.168.56.20`) immediately sends a "Standard query response" claiming to be that resource.
    - **Evidence:** In your capture , you can see the rogue IP `192.168.56.20` responding to multiple LLMNR queries for names like `NONEXISTENTFILE` and its IPv6 equivalent.



Phase 2: Analyzing the Authentication Handshake

Once the victim is tricked, they attempt to authenticate via SMB. We can inspect this handshake to find the captured hash.

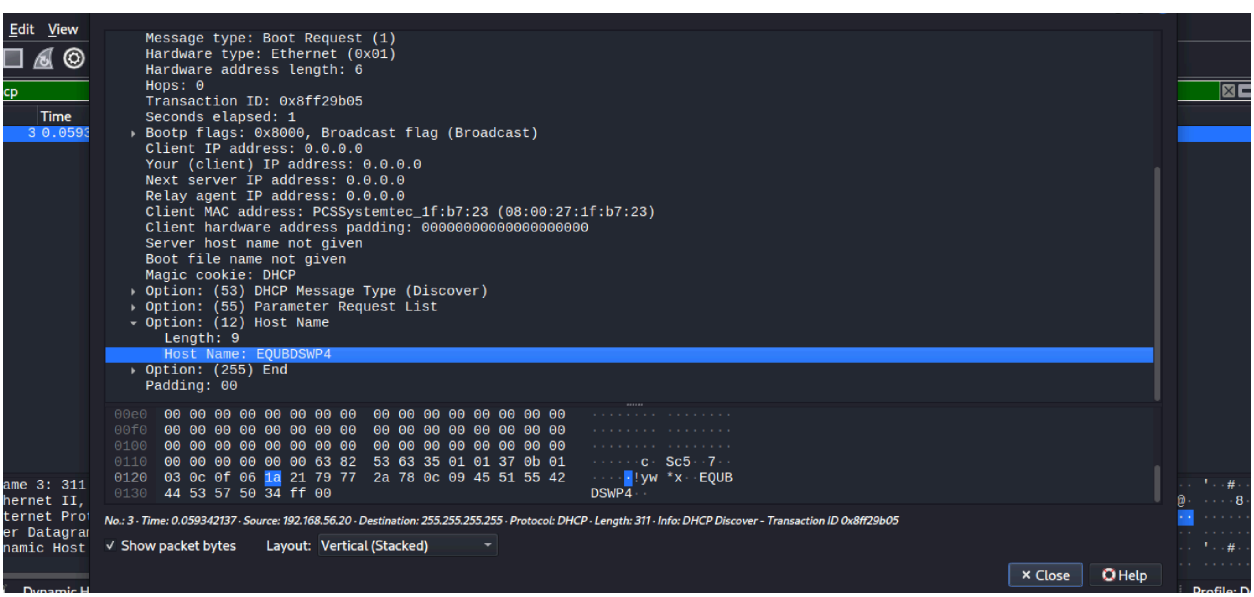
- **Filter Used:** `smb2 || ntlmssp`.
- **The Three-Step Handshake:**
  1. **NTLMSSP_NEGOTIATE:** The client starts the session.
  2. **NTLMSSP_CHALLENGE:** The attacker machine sends a "Server Challenge" (nonce). In your lab (**13.jpg**), the challenge is `e54eb415ec13afeb`.
  3. **NTLMSSP_AUTH:** The victim responds with their encrypted hash, containing the **NTProofStr**.
- **Verification:** Your capture and show the `Session Setup Request` from the user `Lab\naruto_uzumaki07`. This is the exact moment the credentials were intercepted.



Phase 3: Attacker Profiling (DHCP Analysis)

If the attacker's hostname is unknown, we can use DHCP traffic to identify the rogue device's identity.

- **Filter Used:** `dhcp`.
- **Analysis:** By looking at the `DHCP Discover` or `Request` packets from the attacker's MAC address, we can find the **Host Name** option.
- **Evidence:** In your capture , the rogue machine's host name is identified as `EQUBDSWP4`.



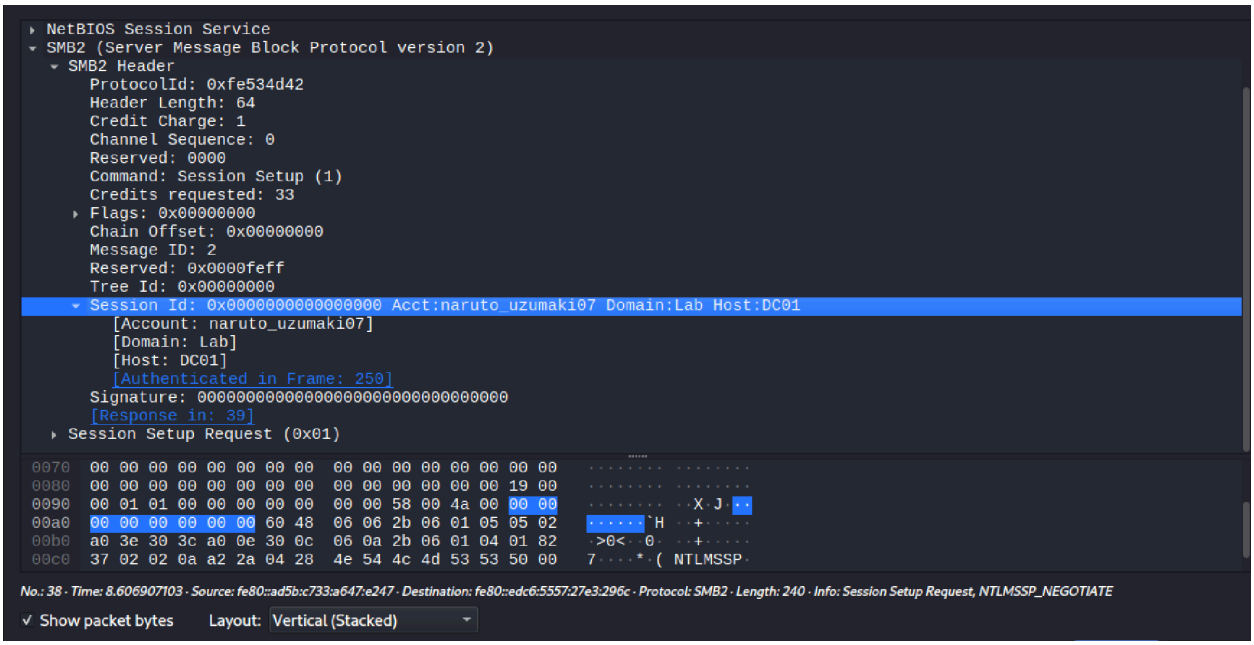
in the formate the hash is captured is this :

Format

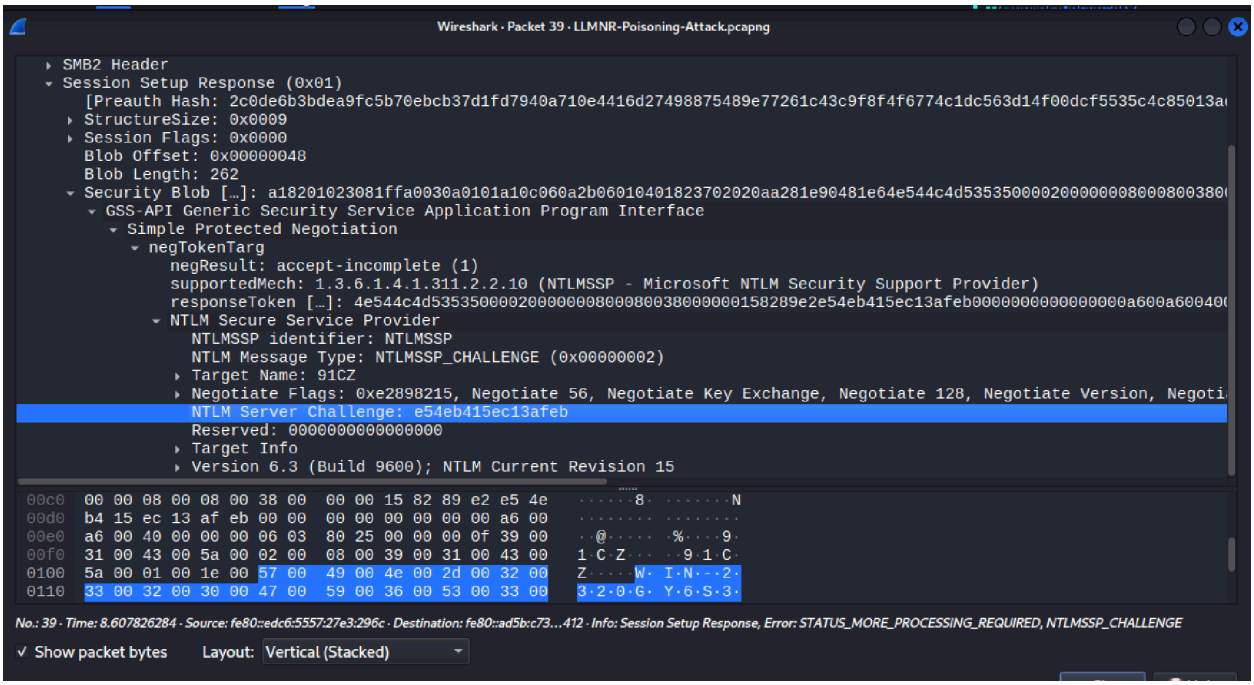
User::Domain:ServerChallenge:NTProofStr:NTLMv2Response(without first 16 bytes/32 characters).

So step by Step you can see in the below images:

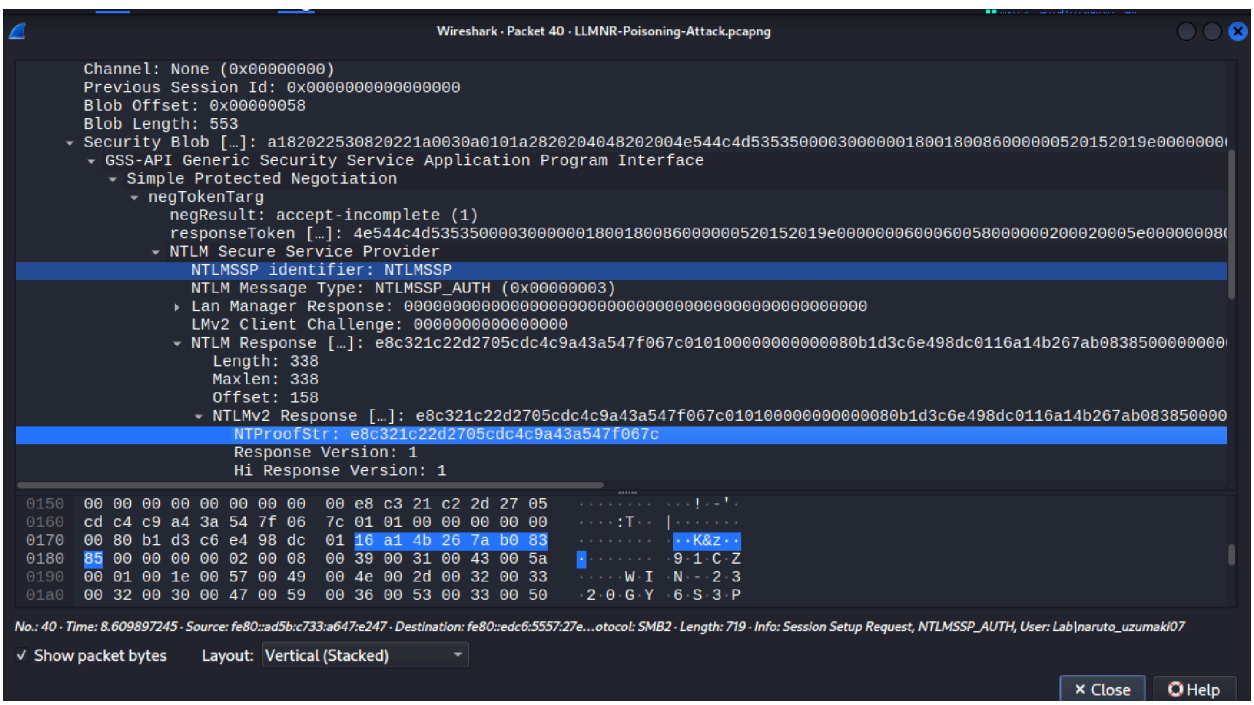
1.



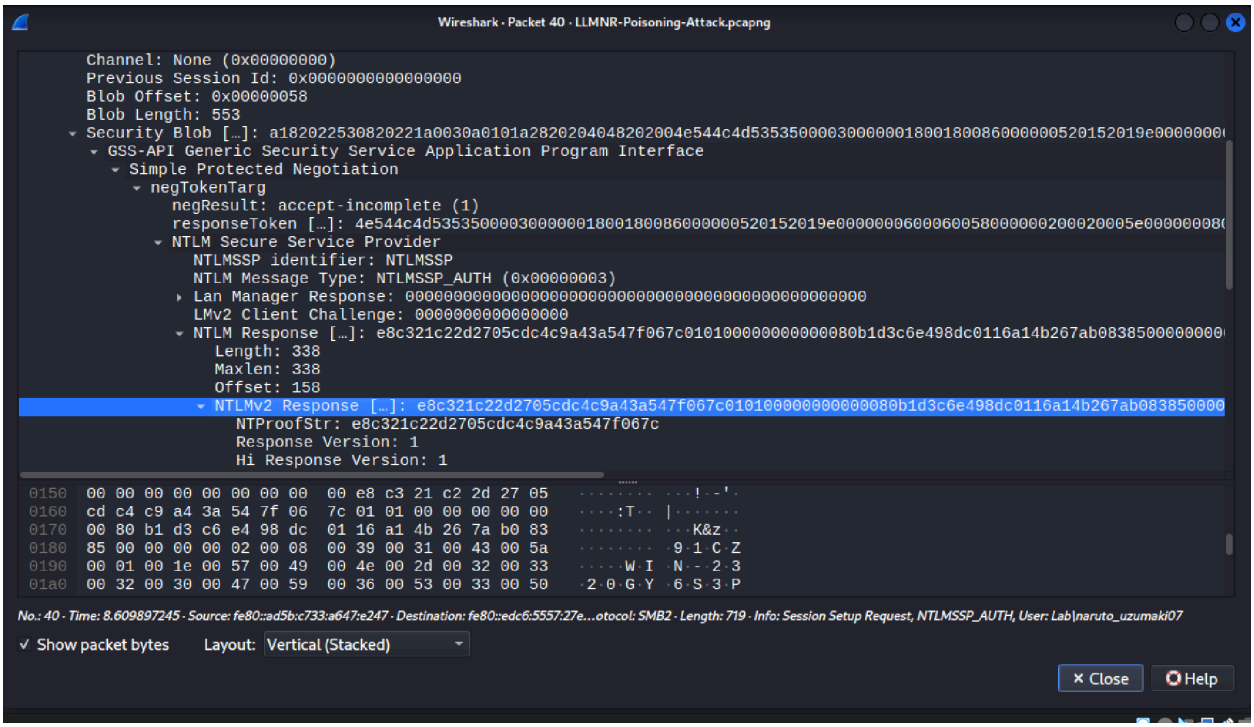
2.


Wireshark · Packet 39 · LLMNR-Poisoning-Attack.pcapng
SMB2 Header
Session Setup Response (0x01)
[Preauth Hash: 2c0de6b3bdea9fc5b70ebcb37d1fd7940a710e4416d27498875489e77261c43c9f8f4f6774c1dc563d14f00dcf5535c4c85013a
StructureSize: 0x0009
Session Flags: 0x0000
Blob Offset: 0x00000048
Blob Length: 262
Security Blob […]: a18201023081ffa0030a0101a10c060a2b06010401823702020aa281e90481e64e544c4d5353500002000000080008003800
GSS-API Generic Security Service Application Program Interface
Simple Protected Negotiation
negTokenTarg
negResult: accept-incomplete (1)
supportedMech: 1.3.6.1.4.1.311.2.2.10 (NTLMSSP - Microsoft NTLM Security Support Provider)
responseToken […]: 4e544c4d5353500002000000080008003800000158289e2e54eb415ec13afeb0000000000000000a600a600400
NTLM Secure Service Provider
NTLMSSP identifier: NTLMSSP
NTLM Message Type: NTLMSSP_CHALLENGE (0x00000002)
Target Name: 91CZ
Negotiate Flags: 0xe2898215, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Version, Negoti
NTLM Server Challenge: e54eb415ec13afeb
Reserved: 0000000000000000
Target Info
Version 6.3 (Build 9600); NTLM Current Revision 15
00c0 00 00 08 00 08 00 38 00 00 00 15 82 89 e2 e5 4e
00d0 b4 15 ec 13 af eb 00 00 00 00 00 00 00 00 a6 00
00e0 a6 00 40 00 00 00 06 03 80 25 00 00 00 0f 39 00
00f0 31 00 43 00 5a 00 02 00 08 00 39 00 31 00 43 00
0100 5a 00 01 00 1e 00 57 00 49 00 4e 00 2d 00 32 00
0110 33 00 32 00 30 00 47 00 59 00 36 00 53 00 33 00
No.: 39 · Time: 8.607826284 · Source: fe80::edc6:5557:27e3:296c · Destination: fe80::ad5b:c73…412 · Info: Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
Show packet bytes
Layout: Vertical (Stacked)

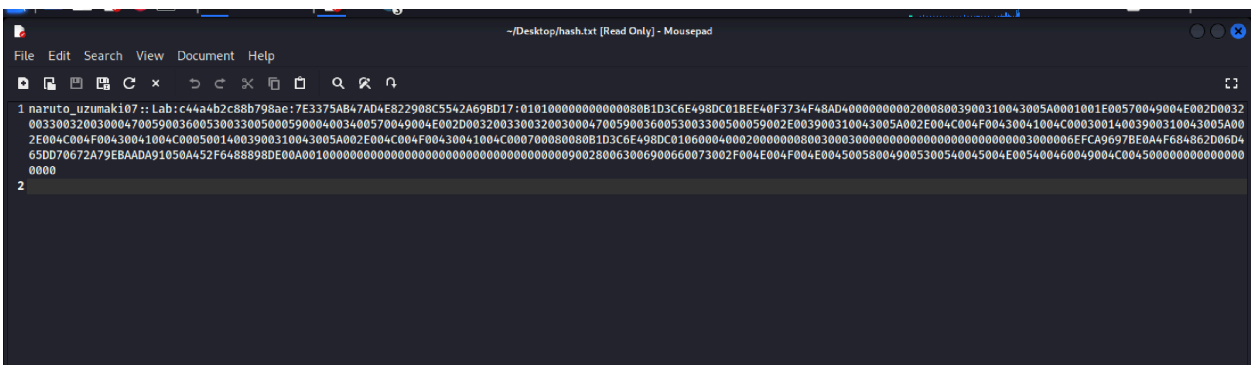
3.


Wireshark · Packet 40 · LLMNR-Poisoning-Attack.pcapng
Channel: None (0x00000000)
Previous Session Id: 0x0000000000000000
Blob Offset: 0x00000058
Blob Length: 553
Security Blob […]: a182022530820221a0030a0101a2820204048202004e544c4d5353500003000000180018008600000052015201 9e00000000
GSS-API Generic Security Service Application Program Interface
Simple Protected Negotiation
negTokenTarg
negResult: accept-incomplete (1)
responseToken […]: 4e544c4d5353500003000000180018008600000052015201 9e00000006000600580000002000200 05e00000008
NTLM Secure Service Provider
NTLMSSP identifier: NTLMSSP
NTLM Message Type: NTLMSSP_AUTH (0x00000003)
Lan Manager Response: 0000000000000000000000000000000000000000000000000000
LMv2 Client Challenge: 0000000000000000
NTLM Response […]: e8c321c22d2705cdc4c9a43a547f067c0101000000000000080b1d3c6e498dc0116a14b267ab0838500000000
Length: 338
Maxlen: 338
Offset: 158
NTLMv2 Response […]: e8c321c22d2705cdc4c9a43a547f067c0101000000000000080b1d3c6e498dc0116a14b267ab083850000
NTProofStr: e8c321c22d2705cdc4c9a43a547f067c
Response Version: 1
Hi Response Version: 1
0150 00 00 00 00 00 00 00 00 00 e8 c3 21 c2 2d 27 05
0160 cd c4 c9 a4 3a 54 7f 06 7c 01 01 00 00 00 00 00
0170 00 80 b1 d3 c6 e4 98 dc 01 16 a1 4b 26 7a b0 83
0180 85 00 00 00 00 02 00 08 00 39 00 31 00 43 00 5a
0190 00 01 00 1e 00 57 00 49 00 4e 00 2d 00 32 00 33
01a0 00 32 00 30 00 47 00 59 00 36 00 53 00 33 00 50
No.: 40 · Time: 8.609897245 · Source: fe80::ad5b:c733:a647:e247 · Destination: fe80::edc6:5557:27e…otocol: SMB2 · Length: 719 · Info: Session Setup Request, NTLMSSP_AUTH, User: Lab\naruto_uzumaki07
Show packet bytes
Layout: Vertical (Stacked)
Close
Help

4.



5. Finally on collecting all the hash is:



using this hash, the attacker cracked in the above that is already shown phase3 of attacking timeline.